

L2 - 10.2. Detection & Analysis

Detection & Analysis / Threat Intel & Containment

Task 1 - Introduction

The Detection and Analysis phase is where the incident response process begins. An alert has been raised at Nexus Financial. Your job is to confirm whether a security incident has occurred, understand how the attacker got in, and determine the full extent of the damage. Every decision that you make in the upcoming rooms depends on how thoroughly this phase is completed.

Task 2 - Detection and Analysis

According to NIST SP 800-61r2, Detection and Analysis is the phase where the team responsible for incident response determines whether a security incident has occurred and builds a complete understanding of it. In large organizations, this work is handled by a dedicated IR team that is separate from the SOC. However, in many organizations, particularly smaller ones like **Nexus Financial**, there is no dedicated IR function. Instead, SOC analysts take on the IR role themselves. L1 analysts handle initial triage and escalation. L2 and L3 analysts lead the deeper investigation and response. The SOC team effectively becomes the IR team. At Nexus Financial, this is exactly the case.

This phase answers two fundamental questions:

- Did a security incident occur, and how did the attacker get in?
- What is the full extent of the damage?

In most SOC environments, detection happens across two levels:

	SOC L1 Analyst	SOC L2 Analyst
Role in Detection	Initial alert triage	Deep investigation and validation
What they do	Receives alert, does initial validations like checking IPs against threat intel, contacting users, etc., and determines true or false positive	Validates L1 finding, traces the attack chain, identifies the root cause, and the entry point

	SOC L1 Analyst	SOC L2 Analyst
Output	Escalation ticket with initial findings	Full incident picture with confirmed IOCs

Analysis: Once an incident is confirmed, the analysis begins. Analysis is the process of understanding the full picture of what happened. This goes beyond simply confirming the incident exists. It means answering deeper questions about the attack:

- How did the attacker gain initial access?
- Which accounts and systems were affected?
- What data may have been accessed or exfiltrated?
- What actions did the attacker take after gaining access?

Scoping is a core part of analysis. It means identifying every affected account, every system accessed, and every piece of data that may have been compromised. But analysis is broader than scoping alone. It also includes correlating evidence across multiple log sources, mapping attacker behavior to known techniques, and building the complete narrative of what happened from the first malicious action to the point of detection.

Poor analysis is one of the most common causes of failed incident response. If the team does not fully understand what was compromised and how, they cannot fully eradicate the threat. An attacker who retains access to even one overlooked account or persistence mechanism can undo weeks of remediation work.

The Feedback Loop: Detection and analysis feed into each other continuously. A new IOC uncovered during analysis may reveal an additional compromised account. That account may lead to further detection of attacker activity that was previously unknown. This cycle continues until no new evidence is emerging and the full picture is confirmed with confidence.

Task 3 - Triggers and Communication

An incident response process does not start on its own. Something must trigger it. Understanding the different sources that can initiate an IR process is important because relying on a single trigger source, such as automated SIEM alerts,

creates blind spots. Incidents that do not generate an automated alert will go undetected unless other trigger sources are active.

Common IR Triggers

Trigger Source	Example
SOC alert escalation	SIEM flags an anomalous sign-in, L1 analyst confirms a true positive, and escalates to L2
User report	Employee reports receiving a suspicious email or notices unexpected account activity
Automated detection	EDR detects and blocks malicious process execution on an endpoint
Third-party notification	A threat intelligence provider or law enforcement notifies the organization of a compromise
Threat intelligence feed	IOC matching the organization's infrastructure appears in an external feed

Each trigger source has a different detection window. A SIEM alert fires within minutes of suspicious activity. A user report may come hours later. A third-party notification could arrive days after a breach has already occurred. This is why organizations that rely on a single trigger source will always have a longer dwell time than those with multiple detection channels active. In the Nexus Financial incident covered in the upcoming tasks, the trigger was a SOC alert escalation. The alert itself was only possible because a basic geo-location detection rule existed in Splunk.

Team Communication During IR: Effective communication is as important as technical skill during an active incident. Common communication failures that slow down IR investigations include:

- Delayed escalation because no clear escalation path is defined
- Key people not being notified because contact lists are outdated
- IT teams unable to provide log access for hours due to approval processes
- MSSP or third-party providers taking days to respond to access requests
- Verbal updates that are never documented, creating gaps in the evidence trail

Answer the questions below

What type of IR trigger would a threat intelligence provider notifying an organization of a compromise be classified as?

Third-party notification

What system should be used to log every action, finding, and decision made during an IR investigation?

Ticketing System

Task 4 - Asset Inventory and IOC Tracker

Two tools are essential throughout the Detection and Analysis phase: the asset inventory and the IOC Tracker. Together, they provide a structured way to map what exists in the environment and track every malicious indicator found during the investigation.

The Asset Inventory: The asset inventory is a reference document that lists all systems, devices, and platforms within the organization. During analysis, the IR team uses it to answer questions like: which systems did this account have access to? Who owns this IP address? What other accounts are associated with this workstation? Without an accurate asset inventory, analysis becomes difficult. The team may miss affected systems simply because they did not know they existed. This is why maintaining an up-to-date asset inventory is a core preparation requirement, a gap that Nexus Financial's own inventory acknowledges, noting that mobile devices are not currently tracked.

The IOC Tracker: The IOC Tracker is a running record of every indicator of compromise discovered during the investigation. It starts with whatever triggered the incident and grows with every new finding. Each entry records the IOC type, its value, where it was found, and any relevant notes.

Common IOC types include:

IOC Type	Example
IP Address	Attacker's sign-in IP flagged as malicious
Domain	Phishing domain used to harvest credentials
Email Address	Sender address used to deliver the phishing email
User Account	Compromised account used by the attacker

IOC Type	Example
File Name	Malicious file downloaded or accessed during the attack

The IOC Tracker is a living document. It is updated throughout every phase of the investigation. Every IOC you find in this room will carry forward into the rooms that follow.

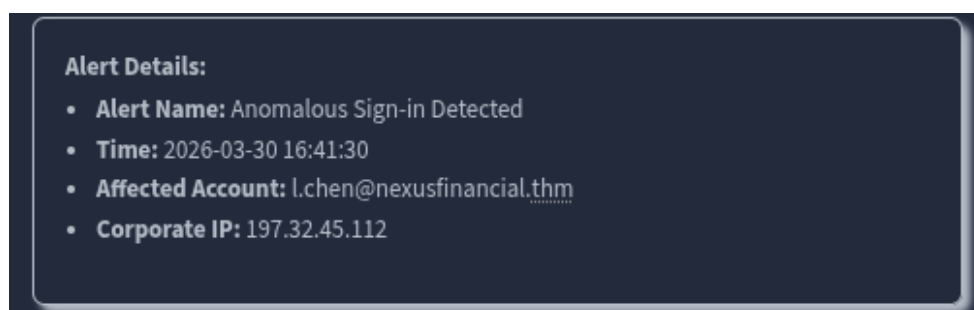
IOC Type	Value	Source	Notes
IP Address	[REDACTED]	Sign-in Logs	Attacker IP
Domain	[REDACTED]	Message Trace	Phishing Domain
Email Address	[REDACTED]	Message Trace	Phishing sender
User Account	[REDACTED]	SIEM Alert	Compromised account

Feeds into

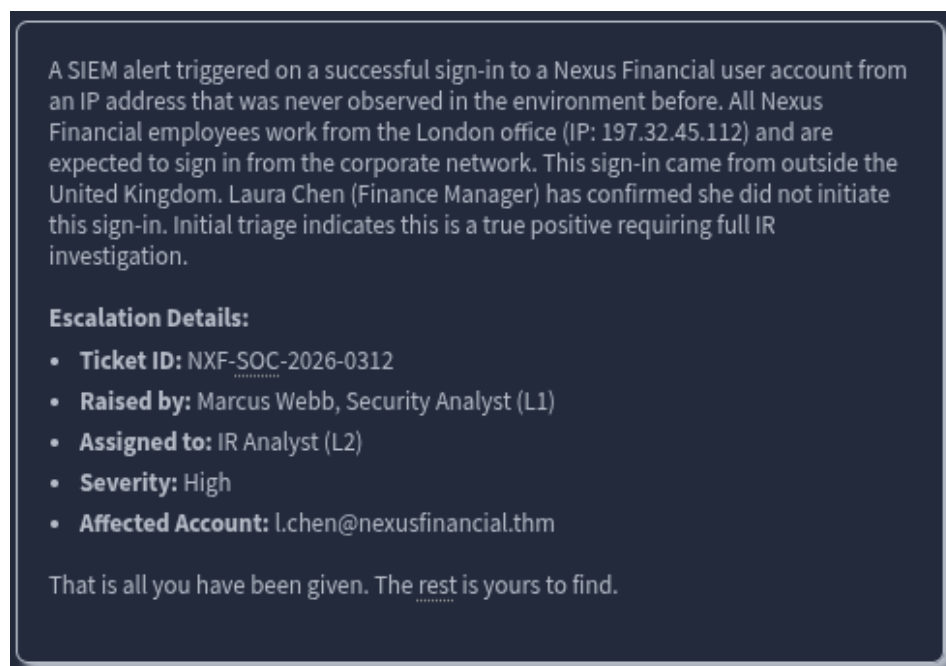
Containment, Eradication, & Recovery

Task 5 - Current Incident Context

An anomalous sign-in alert was raised by the SIEM platform and triaged by Marcus Webb, Nexus Financial's L1 Security Analyst. Marcus confirmed the alert as a true positive and escalated it. You have been assigned to the investigation as the L2 analyst responsible for validating Marcus's findings and leading the full IR investigation. Below is the SIEM alert that Marcus Webb received and triaged.



After triaging the alert, Marcus marked the alert as a true positive and raised the following escalation ticket.



Available Log Sources: Nexus Financial's Microsoft 365 logs have been ingested into Splunk under the index `ir`. The following log sources are available across all practical tasks in this module:

Log Source	Sourcetype	Key Fields
Entra ID Sign-in Logs	<code>azure:aad:signin</code>	<code>userPrincipalName</code> , <code>ipAddress</code> , <code>location.city</code> , <code>location.countryOrRegion</code> , <code>appDisplayName</code> , <code>status.errorCode</code>
Message Trace	<code>o365:reporting:messagetrace</code>	<code>Received</code> , <code>SenderAddress</code> , <code>RecipientAddress</code> , <code>Subject</code> , <code>Status</code> , <code>FromIP</code>
Unified Audit Logs	<code>o365:management:activity</code>	<code>Operation</code> , <code>UserId</code> , <code>Workload</code> , <code>ClientIP</code> , <code>ObjectId</code> , <code>SourceFileName</code> , <code>Name</code> , <code>SubjectContainsWords</code> , <code>DeleteMessage</code>

Task 6 - Detection Practical

You have been handed an escalation from Marcus Webb confirming a suspicious sign-in on the **Nexus Financial** account `l.chen@nexusfinancial.thm`, belonging to Laura Chen, Finance Manager. The escalation ticket provides the corporate IP

address and confirms that this sign-in originated entirely outside the United Kingdom.

This task focuses on the detection side of the phase. Your job is to confirm the suspicious activity in the logs, validate Marcus's finding, and trace the attack back to its origin. Start with the Entra ID sign-in logs. Filter for sign-in activity on Laura Chen's account and look for anything that does not match the corporate IP. Once you have confirmed the suspicious sign-in, think about how the attacker obtained Laura's credentials in the first place. Pivot to the Message Trace and look at what was delivered to her account before the suspicious sign-in occurred. Use the log sources, sourcetypes, and fields listed in Task 5 to build your queries. The questions below will guide your investigation.

Answer the questions below

What was the IP address from which these suspicious sign-in events originated?

223.123.4.50

```
index=ir sourcetype="azure:aad:signin" userPrincipalName="l.chen@nexusfinancial.thm" ipAddress!="197.32.45.112"
```

The screenshot shows the Splunk search results interface. On the left, a list of fields is displayed, with 'ipAddress' selected. The main panel shows a pivot table for the 'ipAddress' field. The table has three columns: 'Values', 'Count', and '%'. The first row shows the value '223.123.4.50' with a count of 18 and a percentage of 100%.

Values	Count	%
223.123.4.50	18	100%

What city did the suspicious sign-in originate from?

Amsterdam

a eventtype 2
a id 7
a index 1
a ipAddress 1
a isInteractive 1
linecount 1
a location.city 1
a location.countryOrRegion 1
a location.geoCoordinates.altitude 1
location.geoCoordinates.latitude 1
location.geoCoordinates.longitude 1
a location.state 1

location.city

1 Value, 100% of events

Selected Yes No

Reports

Top values
Top values by time
Rare values

Events with this field

Values	Count	%
Amsterdam	18	100%

What was the exact timestamp of the first suspicious sign-in on Laura Chen's account?

2026-03-30 16:41:30

```

> 3/30/26 { [-]
    4:41:30.000 PM
      appDisplayName: OfficeHome
      appId: 4765445b-32c6-49b0-83e6-1d93765276ca
      appliedConditionalAccessPolicies: [ [+] ]
      clientAppUsed: Browser
      conditionalAccessStatus: success
      correlationId: f986f0f0-0792-47eb-aa14-d7587ad09376
      createdDateTime: 2026-03-30T16:41:30Z
      deviceDetail: { [+]

```

What was the subject line of the email delivered to Laura Chen before the suspicious sign-in?

HR Policy Update — Immediate Action Required

```

index=ir sourcetype="o365:reporting:messagetrace" RecipientAddress="l.chen@nexusfinancial.thm"

```

```
> 3/30/26 { [-]
4:20:01.693 PM FromIP: 2a00:1450:4864:20::234
MessageId:
<CAA0ajKsy_vZw4BDjaiqNLt7HCpY1Kjxii+LK9rb1BW65PSvNxw@mail.gmail.com>
MessageTraceId: be10618b-d445-472f-66b0-08de8e7831dc
Received: 2026-03-30T16:20:01.693Z
RecipientAddress: l.chen@nexusfinancial.thm
SenderAddress: hr-support@nexus-verify.thm
Size: 53776
Status: Delivered
Subject: HR Policy Update - Immediate Action Required
```

What was the sender domain of the phishing email?

nexus-verify.thm

Task 7 - Detection Practical

You have confirmed the initial compromise of Laura Chen's account and identified the phishing email that delivered it. This task focuses on the analysis side of the phase. Now that detection is confirmed, you need to analyze the full extent of the incident, understanding exactly what the attacker did, which other accounts were affected, and what actions were taken inside the environment after gaining access.

Search across all Nexus Financial accounts for sign-in activity from the attacker's IP. Then look beyond the sign-in logs. A threat actor who has just gained access to a mailbox will typically act quickly to secure their position before being detected. Review the Unified Audit Logs to see which operations were performed from the attacker's IP address within the environment.

Finally, go back to the Message Trace. The phishing email that compromised Laura Chen's account may not have been the only one sent. Understanding the full delivery scope tells you how many accounts were at risk from the very beginning.

Use the log sources, sourcetypes, and fields listed in Task 5 to build your queries. The questions below will guide your investigation.

Answer the questions below

How many Nexus Financial accounts show sign-in activity from the attacker's IP?

2

```
index=ir sourcetype="azure:aad:signin" ipAddress="223.123.4.50" | stats count by userPrincipalName
```

✓ 57 events (before 9/24/26 9:05:07.000 AM) No Event Sampling ▾		Job ▾		▢	→	📄	⬇	🔍 Smart Mode ▾
Events	Patterns	Statistics (2)	Visualization					
Show: 20 Per Page ▾		Format ▾	Preview: On					
userPrincipalName ↕								count ↕
k.patel@nexusfinancial.thm								39
l.chen@nexusfinancial.thm								18

What is the email address of the second compromised account?

k.patel@nexusfinancial.thm

What is the name of the inbox rule created on Laura Chen's account?

Junk Filter Update

```
index=ir sourcetype="o365:management:activity" Operation="New-InboxRule" UserId="l.chen@nexusfinancial.thm"
```

| table _time, UserId, Operation, Name, ClientIP

✓ 1 event (before 9/24/26 9:05:43.000 AM) No Event Sampling ▾		Job ▾		▢	→	📄	⬇	🔍 Smart Mode ▾
Events	Patterns	Statistics (1)	Visualization					
Show: 20 Per Page ▾		Format ▾	Preview: On					
_time ↕	UserId ↕	Operation ↕	Name ↕	ClientIP ↕				
2026-03-30 16:58:48	l.chen@nexusfinancial.thm	New-InboxRule	Junk Filter Update	223.123.4.50:13651				

How many Nexus Financial employee accounts received the initial phishing email?

2

```
index=ir sourcetype="o365:reporting:messagetrace" SenderAddress="*@nexus-verify.thm" | stats count by RecipientAddress
```

Task 8 - Conclusion

In this room, we covered the Detection and Analysis phase of the NIST SP 800-61r2 incident response framework. We explored how detection and analysis work together to build the full picture of an incident. Detection confirms what happened and how the attacker got in, and analysis determines the full extent of the damage. We also saw how these two activities feed into each other continuously, how the L1 to L2 handoff works, and why communication failures during IR directly increase the time an attacker has to operate undetected.

In the practical tasks, starting with a single escalation ticket, we traced the attacker's IP address through sign-in logs, identified the phishing email that delivered the initial compromise, identified every account targeted by the campaign, and discovered the attacker's first post-compromise action within the Nexus Financial environment.